



Universidad Politécnica de San Luis Potosí

Análisis de un ciberataque real y su impacto empresarial.

Colonial Pipeline

Asignatura: CNO IV Programación WAP

Presentan:

- Santiago Isaac Gasca López (184730)
- Andrea Morúa Bravo (185548)
- Isaac Elihu Ríos de la Tejera (184642)
- Luis Arturo Rocha Zarazúa (185050)
- Miguel Ángel Salazar Martínez (183833)
- Edgar Alejandro Valerio Sánchez (185348)

Docente:

Mtro. Servando López Contreras

Índice

Índice	2
Introducción	2
Línea del tiempo	2
Contexto general	3
Tabla técnica del ataque	5
Evaluación de Impacto (Modelo CIA)	7
Cálculo del costo total del ciberataque	8
Lecciones aprendidas y recomendaciones	11
Conclusión	12
Referencias	13

Introducción

El presente reporte técnico tiene como objetivo analizar a profundidad el incidente de ciberseguridad sufrido por Colonial Pipeline en mayo de 2021, uno de los compromisos de infraestructura crítica más significativos en la historia reciente. Para lograr una comprensión integral del evento, este documento se estructura en cinco secciones fundamentales. En primer lugar, se establece un contexto general del ataque, delineando los antecedentes, el desarrollo de la intrusión y la respuesta inmediata de la organización. Posteriormente, se presenta una tabla técnica del ataque que desglosa de manera estructurada los vectores de compromiso, las vulnerabilidades explotadas y las fallas arquitectónicas que permitieron el avance del ransomware dentro de la red corporativa.

Más allá del análisis técnico, el reporte profundiza en las consecuencias del incidente mediante una evaluación del impacto, detallando cómo la paralización del sistema administrativo forzó el cierre de las operaciones físicas y desencadenó una crisis de suministro energético a nivel regional. Para dimensionar el alcance real de esta crisis, se incluye un apartado dedicado al cálculo del costo total del ciberataque, el cual contempla no solo el pago directo de la extorsión, sino también las pérdidas operativas, los costos de mitigación y las afectaciones económicas derivadas. Finalmente, el documento concluye con las lecciones aprendidas y recomendaciones, proporcionando directrices estratégicas, mejores prácticas de segmentación y políticas de gobernanza diseñadas para fortalecer la resiliencia de las organizaciones frente a las crecientes amenazas del panorama cibernético actual.

Línea del tiempo

Figura 1. Línea de tiempo del ciberataque a Colonial Pipeline



Nota. Elaboración propia basada en datos de Brumfield (2021), CISA (2021), Colpipe (2021), Helman (2021), Kelly (2021), Lakshmanan (2021), PHMSA (2022), Threat (2024).

Contexto general

El ataque contra Colonial Pipeline ocurrió en el 7 de mayo de 2021 en Estados Unidos (CrowdStrike Threat Intelligence Team, 2021; U.S. Energy Information Administration EIA, 2021). La empresa, encargada de operar un sistema de 8,850 km que suministra el 45% del combustible de la Costa Este, decidió suspender sus operaciones de manera preventiva tras la intrusión en sus sistemas de TI para evitar riesgos mayores en la infraestructura física (EIA, 2021; CISA, 2023; Brumfield, 2021).

En cuanto a las condiciones previas de ciberseguridad, se identificó el uso de una cuenta VPN antigua cuyos datos de acceso fueron comprometidos (The Hacker News, 2021; U.S. Senate, 2021). Esta cuenta carecía de autenticación multifactorial (MFA), lo que permitió que una simple contraseña fuera suficiente para el acceso inicial (CISA, 2023; Pankov, 2021). Además, la arquitectura de la red evidenció una peligrosa convergencia entre los sistemas informáticos y los operativos, obligando a detener el transporte de combustible por

temor a que el ransomware se propagara hacia funciones críticas (GAO, 2021; Brumfield, 2021; CISA, 2023).

Los factores que facilitaron el éxito del ataque incluyeron la debilidad en el acceso remoto por la falta de MFA y una deficiente gestión de cuentas inactivas, permitiendo que credenciales obsoletas permanecieran válidas (The Hacker News, 2021; U.S. Senate, 2021; CISA, 2023; Pankov, 2021). A esto se sumó una preparación insuficiente para escenarios de contingencia, lo que derivó en una sanción de 986,400 dólares por parte de la PHMSA debido a fallas en la gestión manual de las salas de control durante la crisis (PHMSA, 2023). Finalmente, el impacto fue magnificado por la alta criticidad estratégica de la empresa en el abastecimiento energético nacional, provocando repercusiones económicas y logísticas severas. (CrowdStrike Threat Intelligence Team, 2021; EIA, 2021).

Tabla técnica del ataque

Tabla 2. Análisis de técnica de ataque del ciberataque a Colonial Pipeline

Elemento	Descripción
Tipo de ataque	Ransomware Un ataque de ransomware contra Colonial Pipeline acaparó los titulares de todo el mundo con imágenes de largas filas de automóviles (Easterly y Fanning, 2023) Los operadores de ransomware moderno no solo cifran datos y exigen rescates para descifrarlos, sino que también roban información como palanca para la extorsión. En el caso de Colonial Pipeline, los atacantes extrajeron aproximadamente 100GB de datos de la red corporativa (Pankov, 2021)
Actor o grupo atacante	DarkSide El grupo DarkSide utiliza un modelo ransomware como servicio, proporcionando software e infraestructura relacionada a los socios que llevan a cabo el ataque. Uno de estos socios fue responsable de dirigir el ataque contra Colonial Pipeline (Pankov, 2021)
Vector de entrada	Acceso remoto (Credenciales VPN Vulneradas) Paralizó la red del operador del oleoducto utilizando una contraseña comprometida de una cuenta de red privada virtual (VPN) Lo que implicó obtener un acceso inicial a las redes ya desde el 29 de abril a través de dicha cuenta VPN (Lakshmanan, 2021)
Vulnerabilidad explotada	Falta de MFA y reutilización de contraseñas El inicio de sesión de la VPN —que no contaba con protección de autenticación multifactor— estaba activo, pero sin uso en el momento del ataque (Lakshmanan, 2021)
Etapas del ataque (MITRE ATT&CK)	• Acceso inicial: obteniendo un punto de apoyo inicial en las redes desde el 29 de abril a través de la cuenta VPN (Lakshmanan, 2021) • Exfiltración: los atacantes extrajeron aproximadamente 100GB de datos de la red corporativa. (Pankov, 2021) • Impacto: algunas computadoras estaban cifradas... DarkSide utiliza algoritmos de cifrado potentes, por lo que la restauración de datos sin la clave correcta es imposible. (Pankov, 2021)

Sistemas o servicios comprometidos	Sistema de facturación y OT Los empleados tuvieron desactivar algunos sistemas de información, en parte debido a que algunas computadoras estaban cifradas, y en parte para evitar que la infección se extendiera. (Pankov, 2021) Desconectó de forma proactiva sistemas específicos y detuvo todas las operaciones del oleoducto Es probable que la falta de visibilidad sobre el estado de seguridad de sus sistemas de tecnología operativa (OT) fuera lo que llevó a Colonial a detener sus operaciones en un primer momento (Brumfield, 2021)
Duración del incidente	5 días El 7 de mayo de 2021, Colonial Pipeline fue víctima de una infección por ransomware (CrowdStrike Threat Intel Team, 2021) Y restableció las operaciones en todo su sistema de oleoductos el 12 de mayo después de una infección por ransomware (Lakshmanan, 2021)
Mecanismos de detección y respuesta	Aislamiento de red, notificación al FBI y decomiso de servidores Investigadores externos del incidente rápidamente descubrieron qué pasó y dónde estaban los datos robados, y se comunicaron con el FBI. Por su parte, la agencia se comunicó con el proveedor de servicios de Internet propietario del servidor que alojaba la información cargada y les pidió que la aislaran (Pankov, 2021) Colonial recurrió a las autoridades federales y contrató a FireEye Mandiant para llevar a cabo una investigación de respuesta ante incidentes (Brumfield, 2021)

Nota. Elaboración propia a partir de información obtenida de Brumfield (2021), CrowdStrike Threat Intel Team (2021), Easterly y Fanning (2023), Lakshmanan (2021) y Pankov (2021).

Evaluación de Impacto (Modelo CIA)

Tabla 3. *Análisis del impacto del ciberataque a Colonial Pipeline bajo la Tríada CID*

Principio	Descripción del Impacto	Evidencia del Caos
Confidencialidad	Exfiltración y exposición de datos corporativos	Se exfiltraron aproximadamente 100 GB de datos corporativos antes del proceso de cifrado, los cuales fueron utilizados como mecanismo de doble extorsión (Nikolay Pankov, 2021; Threat, 2021). Posteriormente, el FBI logró que se aislara el servidor del proveedor de internet donde los atacantes alojaban los datos, mitigando parcialmente la exposición de la información (Nikolay Pankov, 2021).
Integridad	Cifrados maliciosos y alteración de los sistemas de TI	Múltiples equipos y sistemas de la red de TI (Tecnologías de la Información) fueron cifrados por el ransomware DarkSide, alterando y bloqueando el acceso a archivos operativos y al sistema de facturación (Brumfield, 2021; Nikolay Pankov, 2021). Los sistemas quedaron inoperables e inaccesibles, alterando de forma severa el entorno digital de la compañía
Disponibilidad	Paralización de infraestructura	Colonial Pipeline apagó de forma preventiva sus redes de Tecnología Operativa (OT) para evitar la propagación de la infección, lo que interrumpió el

	crítica y redes de OT	transporte de 2.5 millones de barriles diarios de combustible (45% del suministro de la Costa Este) (Brumfield, 2021; Threat, 2021). Además, la incapacidad para restablecer el entorno de forma manual prolongó la inactividad, derivando en una propuesta de multa de casi \$1 millón de dólares por parte del gobierno estadounidense (Lakshmanan, 2022).
--	-----------------------	--

Nota. Elaboración propia basada en datos de Brumfield (2021), Nikolay Pankov (2021), Lakshmanan (2022) y Threat (2021).

Cálculo del costo total del ciberataque

Para la cuantificación de las pérdidas y costos derivados del ciberataque se tomaron como base los indicadores económicos y financieros oficiales vigentes el 7 de mayo de 2021:

- **Tipo de Cambio Oficial (USD/MXN):** \$19.9223 MXN por dólar (BANXICO, 2021).
- **Precio del Barril de Petróleo:** \$64.96 USD por barril (FRED, 2021a).
- **Cotización de Bitcoin:** \$57,373.88 USD por unidad (FRED, 2021b).

Tabla 4. Estimación económica del costo total del ciberataque a *Colonial Pipeline*

Tipo de costo	Descripción	Estimación (MXM)
Pérdidas operativas	Colonial Pipeline transporta 2,500 millones de barriles de petróleo al día. (Brumfield, 2021). Según la nota hecha por Hacker News, Colonial quedó inhábil por 5 días. "Nuestra coordinación con los actores gubernamentales fue oportuna, eficiente y eficaz, como demuestra nuestra capacidad para reiniciar rápidamente el oleoducto de forma segura cinco días después de ser atacados — tras operaciones manuales localizadas realizadas antes del reinicio oficial." (Lakshmanan, 2022). Haciendo tres operaciones matemáticas podemos aproximar la pérdida de dinero que se perdió en esos 5 días por el no envío de este producto.	Valor de Barril Petróleo en dólares × barriles vendidos al día = $64.96 \times 2,500,000 = 162,400,000$ dólares $162,400,000 \text{ dólares} \times 19.9223 \text{ pesos} = 3,235,381,520 \text{ pesos en un día}$ $3,235,381,520 \text{ pesos} \times 5 \text{ días} = 16,176,907,600 \text{ pesos en 5 días inhábiles.}$
Daños reputacionales	Pérdida de la confianza pública y descontento social, al detener sus operaciones para evitar la propagación del malware, se interrumpió cerca del 45% del suministro de combustible de la Costa Este de EE. UU. Esto provocó compras de pánico, filas kilométricas en gasolineras y desabasto, exponiendo a la empresa ante la opinión pública como un eslabón frágil que afectó la vida cotidiana de millones de personas. (CISA,2023)	Aproximadamente de 15 a 30 millones de dólares $30,000,000 \times 19.9223 \text{ pesos} = 597,669,000 \text{ pesos}$

Costos técnicos	El 8 de junio de 2021, el CEO de Colonial Pipeline, Joseph Blount, fue citado a testificar bajo protesta de decir verdad ante el Comité de Seguridad Nacional y Asuntos Gubernamentales del Senado de EE. UU. Se detalló que, en un periodo de 5 años, Colonial Pipeline invirtió aproximadamente \$200 millones de dólares en total en sus sistemas de TI. (Hrg, 2021)	200,000,000 dólares por 19.9223 pesos = 3,985,860,000 pesos
Costos Legales / regulatorios	La Administración de Seguridad de Oleoductos y Materiales Peligrosos (PHMSA) del Departamento de Transporte de EE. UU. ha propuesto una multa de 986,400 de dólares a Colonial Pipeline por violar las normativas federales de seguridad. (PHMSA, 2022)	986,400 dólares de multa x 19.9223 pesos = 18,894,309.32 pesos
Pago de rescate o extorción	El incidente también llevó a la empresa a pagar 4,4 millones de dólares en rescate al sindicato del cibercrimen para recuperar el acceso a su red informática, aunque el gobierno estadounidense logró recuperar una parte significativa de los fondos digitales pagados. Lakshmanan, R. (2021) El Departamento de Justicia de EE. UU. anunció el lunes que ha recuperado 63,7 bitcoins (actualmente valorados en 2,3 millones de dólares) pagados por Colonial Pipeline a los extorsionadores de ransomware DarkSide el 8 de mayo. Lakshmanan, R. (2021)	4,400,000 dólares x 19.9223 pesos = 87,658,120 pesos para liberar el sistema 57,373.88 valor bitcoin en dólares x 63.7 bitcoins = 3,654,716.156 dólares recuperados por EU 3,654,716.156 dólares x 19.9223 pesos = 70,254,608.67 pesos dinero recuperado por los EU. 87,658,120 pesos pesos para liberar el sistema - 70,254,608.67 pesos recuperados por EU = 17,403,511.33 pesos perdidos por pago a ransomware.
TOTAL ESTIMADO	La suma de toda la perdida aproximadamente.	16,176,907,600 pesos en 5 días inhábiles + 18,894,309.32 pesos de multa + 17,403,511.33 pesos perdidos por pago a ransomware + 3,985,860,000 pesos en costo técnico + 597,669,000 pesos de reputación =

		16,217,788,949.65 pesos aproximadamente
--	--	---

Nota. Elaboración propia basada en datos macroeconómicos del Banco de México (BANXICO, 2021), la Reserva Federal de ST. Louis (FRED, 2021), CISA (2021), Hrg (2021), CSO Online (2021) y *The Hacker News* (2021, 2022).

Tabla 5. Estimación económica del costo total del ciberataque a *Colonial Pipeline*

Concepto	Monto Estimado (USD)	Relación / Impacto
Presupuesto Anual de Ciberseguridad (<i>Sector Energético - Colonial</i>)	\$4.0 - \$6.0 MDP	Representa el ~12% de su gasto anual en TI.
Costo Total del Incidente (<i>En solo 5 días de paro</i>)	\$30.4 MDP	6 veces el presupuesto anual de seguridad.

Nota. Elaboración propia basada en datos macroeconómicos del Banco de México (BANXICO, 2021), la Reserva Federal de ST. Louis (FRED, 2021), CISA (2021), Hrg (2021), CSO Online (2021) y *The Hacker News* (2021, 2022).

Lecciones aprendidas y recomendaciones

Las fallas técnicas críticas incluyeron la falta de segmentación entre las redes de Tecnologías de la Información (IT) y de la Operación (OT), las cuales se encontraban tan entrelazadas que un compromiso en la red corporativa amenazaba con colapsar los sistemas operativos (Brumfield, 2021). Asimismo, la empresa padecía una "ceguera técnica" por carecer de la tecnología necesaria para auditar y determinar el estado de seguridad de sus entornos de sistemas de control industrial (ICS), lo que impidió dimensionar con precisión el impacto real del ransomware (Brumfield, 2021).

En cuanto a las fallas humanas y de gestión, se evidenció un diseño deficiente en los procesos de negocio debido a que la interrupción en la distribución de combustible no provino de las tuberías físicas, sino del secuestro del sistema de facturación, sin el cual la empresa no pudo operar administrativamente (Pankov, 2021). Además, la decisión directiva de apagar los sistemas de manera preventiva reflejó una falla en la gestión de riesgos y una desconfianza generalizada en su propia postura de seguridad operativa (Brumfield, 2021).

Para mitigar y reducir estos daños, se habrían requerido buenas prácticas orientadas a elevar el riesgo cibernético al nivel de la junta directiva y los directores ejecutivos como una prioridad estratégica (Easterly, 2023). También fue clave mantener políticas de transparencia y aviso inmediato a agencias federales, lo que ayudó a aislar servidores con datos robados (Brumfield, 2021), junto con una arquitectura de segmentación estricta y planes de recuperación y respaldos continuamente probados (Brumfield, 2021).

Finalmente, las recomendaciones aplicables al contexto mexicano y latinoamericano exigen implementar una segmentación estricta mediante VLANs y Listas de Control de Acceso para evitar casos similares al sufrido por Pemex con DoppelPayme (Riquelme, 2019). Adicionalmente, resulta indispensable incrementar la contratación, formación y profesionalización de talento en ciberseguridad para sectores críticos, impulsando desde las

universidades y programas técnicos las oportunidades para nuevos perfiles en áreas de respuesta a incidentes y protección de infraestructuras (Riquelme, 2026).

Conclusión

El ataque de ransomware a Colonial Pipeline marcó un punto de inflexión decisivo en la historia de la ciberseguridad industrial, demostrando que la vulnerabilidad de las infraestructuras críticas representa un riesgo inminente para la estabilidad económica y la seguridad nacional. Este incidente evidenció que no es necesario que un cibercriminal comprometa directamente los sistemas de control físico o Tecnología de Operaciones (TO) para paralizar una operación a gran escala; la infección de la red de Tecnologías de la Información (TI) y el posterior secuestro del sistema de facturación bastaron para forzar un cierre preventivo de toda la red de oleoductos. Esta disrupción operativa, agravada por una deficiente segmentación de redes y la falta de visibilidad en los entornos industriales, generó un impacto económico inmediato al interrumpir el suministro del 45 % de la gasolina consumida en la costa este de los Estados Unidos. Como resultado, se desataron compras de pánico, el precio del combustible se incrementó en un 4 % en la región y la empresa se vio acorralada a pagar un rescate de casi 5 millones de dólares en criptomonedas, mientras el gobierno federal se veía obligado a emitir exenciones de transporte de emergencia para mitigar la crisis.

Más allá de las pérdidas financieras y operativas, las fallas exhibidas por Colonial Pipeline sirvieron como un severo llamado de atención a nivel global que redefinió la percepción del riesgo cibernético. A raíz de este suceso, la ciberseguridad dejó de ser considerada un asunto puramente tecnológico para consolidarse como un pilar innegociable de la gobernanza corporativa que debe ser priorizado al más alto nivel directivo. El ataque actuó como un catalizador que aceleró la adopción de arquitecturas de confianza cero, la implementación de planes de continuidad de negocio más robustos y la creación de alianzas estratégicas de defensa conjunta entre el sector público y privado.

Referencias

- Brumfield, C. (2021, May 10). Colonial Pipeline shutdown highlights need for better OT cybersecurity practices. CSO Online. <https://www.csoonline.com/article/570705/colonial-pipeline-shutdown-highlights-need-for-better-ot-cybersecurity-practices.html>
- Brumfield, C. (10 de 05 de 2021). Colonial Pipeline shutdown highlights need for better OT cybersecurity practices. Obtenido de Colonial Pipeline shutdown highlights need for better OT cybersecurity practices
- Easterly, J. (07 de 05 de 2023). The Attack on Colonial Pipeline: What We've Learned & What We've Done Over the Past Two Years. Obtenido de The Attack on Colonial Pipeline: What We've Learned & What We've Done Over the Past Two Years: Enforcement Action Details: 32022026NOPV | Enforcement Data | PHMSA. (2022). Dot.Gov. <https://primis.phmsa.dot.gov/enforcement-data/case/32022026NOPV>
- Helman, C. (2021, May 10). FBI: Colonial Pipeline Hacked By 'Apolitical' Group DarkSide. *Forbes*. <https://www.forbes.com/sites/christopherhelman/2021/05/10/fbi-colonial-pipeline-hacked-by-apolitical-group-darkside/?sh=20ffb0134418>

Hrg, S. (2021). THREATS TO CRITICAL INFRASTRUCTURE: EXAMINING THE COLONIAL PIPELINE CYBERATTACK HEARING BEFORE THE COMMITTEE ON HOMELAND SECURITY AND GOVERNMENTAL AFFAIRS UNITED STATES SENATE ONE HUNDRED SIXTEENTH CONGRESS FIRST SESSION.

<https://www.govinfo.gov/content/pkg/CHRG-117shrg46569/pdf/CHRG-117shrg46569.pdf>

Kelly, M. L. (2021, June 3). The Colonial Pipeline CEO Explains The Decision To Pay Hackers A \$4.4 Million Ransom. *NPR*.

<https://www.npr.org/2021/06/03/1003020300/colonial-pipeline-ceo-explains-the-decision-to-pay-hackers-4-4-million-ransom>

<https://x.com/Colpipe>. (2021, May 15). Colonial Pipeline (@Colpipe) en X. X (Formerly Twitter). <https://x.com/Colpipe/status/1393529174598504454?s=46>

Lakshmanan, R.. (2021, June 7). *The Hacker News*. The Hacker News. <https://thehackernews.com/2021/06/hackers-breached-colonial-pipeline.html>

Lakshmanan, R. (2022, May 10). *The Hacker News*. The Hacker News. <https://thehackernews.com/2022/05/us-proposes-1-million-fine-on-colonial.html>

Nikolay Pankov. (2021, May 17). El ataque de ransomware a Colonial Pipeline. *Blog Oficial de Kaspersky; Kaspersky*. <https://latam.kaspersky.com/blog/pipeline-ransomware-mitigation/21893/>

Pankov, N. (17 de 05 de 2021). El ataque de ransomware a Colonial Pipeline. Obtenido de El ataque de ransomware a Colonial Pipeline:

Riquelme, R. (14 de 11 de 2019). Hackeo a Pemex puede considerarse como un delito de extorsión. Obtenido de Hackeo a Pemex puede considerarse como un delito de extorsión: <https://www.eleconomista.com.mx/tecnologia/Hackeo-a-Pemex-puede-considerarse-como-un-delito-de-extorsion-20191113-0095.html>

Riquelme, R. (15 de 06 de 2026). Pese a déficit, trabajadores de ciberseguridad en América Latina voltean a Estados Unidos. Obtenido de Pese a déficit, trabajadores de ciberseguridad en América Latina voltean a Estados Unidos: <https://www.eleconomista.com.mx/tecnologia/pese-deficit-trabajadores-ciberseguridad-america-latina-voltean-estados-unidos-20260615-818599.html>

The Attack on Colonial Pipeline: What We've Learned & What We've Done Over the Past Two Years | CISA. (2023, May 7). *Cybersecurity and Infrastructure Security Agency CISA*. <https://www.cisa.gov/news-events/news/attack-colonial-pipeline-what-weve-learned-what-weve-done-over-past-two-years>

Threat, C. (2024). How Ransomware Adversaries Reacted to the DarkSide Attack. In *Crowdstrike.com*. <https://www.crowdstrike.com/en-us/blog/how-ransomware-adversaries-reacted-to-the-darkside-pipeline-attack/>